Risk Analysis with EBIOS RM, Security Policy (PSSI) and Business Continuity Plan (PCA) for an AI-Enabled Supply Chain Management Information System

Introduction

Artificial intelligence is now embedded in the core of supply chain management. Demand forecasts, replenishment quantities, anomaly alerts and supplier-delay predictions increasingly drive real purchasing and logistics decisions. These systems depend on critical data, external integrations, privileged users and machine-learning models, so they combine the classic risks of an information system (ransomware, fraud, data leaks, outages) with new ones: a model can be poisoned, copied, evaded or manipulated through its inputs and outputs.

This project studies the AI-SCMIS of a fictional distributor that supplies spare parts to regional warehouses and customer service centres. The company receives orders from a sales platform, buys from external suppliers, stores goods in warehouses and ships through contracted carriers. Its AI layer provides demand forecasting, inventory recommendations, anomaly detection, supplier-risk estimation and delivery-time prediction, while staff remain responsible for validating consequential recommendations.

Our objectives are to (1) analyse the risks with EBIOS RM, (2) propose a PCA/PRA able to keep the essential activities running during a major incident, and (3) write a PSSI adapted to a system that includes AI components.

Methodological note. The scenario is illustrative. Scales, maturity levels, RTO/RPO values and thresholds used in this report are working assumptions made by the team; a real implementation would validate them with the organisation's own data, processes, legal obligations and risk appetite.

Definitions

EBIOS RM (Expression des Besoins et Identification des Objectifs de Sécurité – Risk Manager). Risk analysis method published by the French national cybersecurity agency (ANSSI). It organises the study in five workshops and combines a compliance-based approach (security baseline) with a scenario-based approach (strategic and operational scenarios). It is compatible with ISO/IEC 27005 and ISO/IEC 27001.

PSSI (Politique de Sécurité des Systèmes d'Information). Strategic document that defines the rules, responsibilities and measures protecting the confidentiality, integrity, availability and traceability of information and systems, and that frames the behaviour of users and administrators.

PCA (Plan de Continuité d'Activité). Set of procedures and arrangements that allow the critical activities of an organisation to continue, possibly in degraded mode, during a major incident.

PRA (Plan de Reprise d'Activité). Technical complement of the PCA that describes how systems and data are restored after an interruption, within the targeted recovery time (RTO) and data-loss limit (RPO).

ISO/IEC 27090. Standard of the ISO/IEC 27000 family dedicated to addressing security threats and compromises of AI systems. As described in the course material, it is organised in three key clauses: Clause 5 (applying information security to AI: governance, zero trust, software engineering practices, supply chain, threat modelling, red teaming), Clause 6 (types of potential compromise to AI systems) and Clause 7 (mitigations), plus three annexes (mapping of attacks to the AI life cycle, AI-specific versions of conventional attacks, federated machine learning). It complements ISO/IEC 27001 (information security management), ISO/IEC 42001 (AI governance) and ISO/IEC 23894 (AI risk management).

Reading key for EBIOS RM codes. VM = business value; BS = supporting asset; ER = feared event; RS = risk source; OV = target objective; SS = strategic scenario; OS = operational scenario; M = security measure.

Chapter 1 — Risk Analysis with EBIOS RM

Workshop 1 — Framing and Security Baseline

1.1 Study framework

The purpose of the study is to identify the risks weighing on the AI-SCMIS (data, models, processes and integrations) and to define a security baseline adapted to the distributor.

1.2 Study scope

Strategic perimeter. The distributor's mission is to guarantee product availability and delivery reliability for regional warehouses and customer service centres, while reducing excess stock, avoidable transport costs and disruptions. The AI-SCMIS supports five objectives: predicting demand, recommending replenishment quantities and timing, identifying abnormal orders or stock movements, anticipating delivery delays, and giving managers traceable, data-supported decisions. AI outputs are decision support, not unquestionable facts.

The business values retained for the study are:

ID	Business value	Description
VM1	Demand forecasting and replenishment planning	Forecasts, safety-stock logic and purchase plans that drive availability and costs
VM2	Order-to-delivery process	Order management, inventory tracking, warehouse operations and shipment tracking
VM3	Operational and historical data	Orders, stock levels, receipts, sales history, carrier events, with their lineage
VM4	Supplier and carrier relationships	Supplier records, lead times, contracts, performance and carrier agreements

ID	Business value	Description
VM5	AI models and their governance	Models, features, model registry (versions, evaluations, approvals) – proprietary know-how
VM6	Customer personal data	Data needed for fulfilment and customer service
VM7	Traceability and audit trail	Logs of recommendations, approvals, overrides and resulting actions

Operational perimeter. Five critical processes are retained because their compromise would strongly affect the business:

- **P1 – Data collection and integration:** APIs, scheduled imports, barcode scanners, warehouse devices and manual entries are validated, standardised and matched by the integration service.
- **P2 – Model training, validation and deployment:** training on historical data, evaluation, approval in the model registry and deployment.
- **P3 – Inference and recommendation:** forecasting, replenishment, anomaly detection, supplier-risk and delivery-time prediction.
- **P4 – Human decision and execution:** review, acceptance, modification or rejection of recommendations; purchase orders and shipments.
- **P5 – Backup and restoration:** recovery of operational data, historical data and model artefacts.

The supporting assets are:

ID	Supporting asset	Linked values
BS1	ERP, WMS, TMS and inventory systems	VM2, VM3, VM4
BS2	Integration hub, APIs and ETL/ELT services	VM3, VM4
BS3	Operational database, data lake and data warehouse	VM3, VM6, VM7
BS4	AI and analytics engine (forecasting, optimisation, anomaly and risk models)	VM1, VM5
BS5	Model registry and ML pipeline (training, CI/CD)	VM5, VM7
BS6	Role-based dashboards and user workstations	VM1, VM2, VM7
BS7	IoT devices, barcode scanners and warehouse devices	VM2, VM3
BS8	Network, hosting and cloud infrastructure	All
BS9	Privileged accounts and service accounts	All
BS10	Third-party services (carrier APIs, supplier exchanges, weather and calendar feeds)	VM3, VM4

1.3 Feared events

The severity of feared events is assessed on a four-level scale.

Level	Name	Reference impact
G1	Minor	Disruption under 4 hours absorbed by normal operations; no customer or regulatory impact
G2	Significant	Stockouts or excess stock on a limited product range; delays of 1–2 days; limited internal data exposure
G3	Critical	Multi-warehouse disruption for 2–5 days; major financial loss; personal-data breach or contractual penalties
G4	Catastrophic	Distribution halted for more than 5 days; loss of key customers; severe legal consequences; survival of the business threatened

ID	Feared event	Values	Criterion	Severity
ER1	Poisoned or manipulated data (or model) causes biased forecasts and wrong replenishment orders	VM1, VM3, VM5	Integrity	G3
ER2	AI-SCMIS, ERP or WMS unavailable for more than 24 hours	VM2, VM3	Availability	G4
ER3	Leak of customer personal data and of supplier contract or pricing data	VM4, VM6	Confidentiality	G3
ER4	Theft or functional reconstruction of proprietary models	VM5	Confidentiality	G2
ER5	Fraudulent or unauthorised purchase orders, supplier changes or invoice redirection	VM2, VM4	Integrity	G3
ER6	Loss or alteration of the audit trail and of the model registry	VM5, VM7	Integrity / traceability	G3
ER7	Undetected model drift or silent degradation leading to stockouts or excess inventory	VM1	Integrity / availability	G2
ER8	Manipulated model inputs or outputs (prompt injection, malicious content in dashboards) leading to harmful decisions	VM1, VM7	Integrity	G2

1.4 Security baseline

The baseline is built from the following references.

Reference	Role in the study
ISO/IEC 27001 and 27002	Information security management system and control catalogue
ISO/IEC 42001 and 23894	AI governance and AI risk management
ISO/IEC 27090	Threats and mitigations specific to AI systems (clauses 5, 6 and 7)
NIST AI RMF	Complementary AI risk framework for international contexts
ANSSI IT hygiene guide	Baseline of good practices
Law No. 18-07 (Algeria)	Protection of natural persons in the processing of personal data